

АВТОМАТИЗАЦИЯ ОЦЕНКИ И РЕГУЛИРОВАНИЯ РИСКОВ РЕАЛИЗАЦИИ КИБЕРАТАК: ПРОЦЕДУРЫ СБОРА, ОБРАБОТКИ И ХРАНЕНИЯ ДАННЫХ

Г.А. Остапенко, А.А. Остапенко, М.В. Кондратьев,
А.С. Кривошеин, Ю.В. Макаров

Работа посвящена формализации модуля централизованного сбора, обработки и хранения информации о компонентах графовой модели кибератак. Целью настоящей работы является постановка задач, которые должны решаться внедрением модуля в систему, а также реализации самих алгоритмов, которые должны обеспечивать автоматизированный сбор данных о компонентах графа кибератак, их обработку и обогащение, связанное с повышением целостности и качества данных.

Ключевые слова: кибербезопасность, уязвимость, техники атак, шаблоны атак, оценка рисков, машинное обучение, CVSS, EPSS, MITRE ATT&CK.

Введение

В контексте создания модуля централизованного сбора, обработки и хранения информации о компонентах кибератак, основными задачами являются:

- 1) формирование модели компонентов кибератак,
- 2) обработка данных графа компонентов кибератак,
- 3) генерация ребер графа компонентов кибератак.

Формирование модели компонентов кибератак, которая представляет собой ориентированный мультиграф $G=(N, E)$, где множество узлов N включает следующие элементы:

- шаблоны кибератак;
- техники кибератак;
- слабости, из-за которых возможна реализация атаки;
- уязвимости атакуемых систем,

а множество ребер E включает взаимосвязи между следующими парами узлов:

- шаблоны и техники;
- техники и слабости;
- слабости и уязвимости.

1) Обработка данных графа компонентов кибератак, для чего необходимо назначить веса компонентам графа. У ребер весом является вероятность перехода от родительского узла к

конкретному дочернему узлу, что характеризует поведение злоумышленника в выборе того или иного компонента кибератаки для его последующей реализации:

$$W_{\text{узел} \rightarrow \text{дочерний узел}} = \frac{P_{\text{дочерний узел}}}{\sum_{j=1}^N P_{\text{дочерний узел } jj}},$$

где N – количество дочерних узлов для материнского узла.

Весом узла является вероятность реализации атаки через данный узел и потенциальный ущерб системе в результате успеха кибератаки. Для узлов уязвимостей вероятность рассчитывается на основе статистических калькуляторов, например, EPSS для CVE. Для остальных типов узлов вероятность рассчитывается с помощью дочерних узлов графовой модели по следующей формуле:

$$P_{\text{узел}} = \sum_{i=1}^n (P_{\text{дочерний узел } i} \times \prod_{j=1, j \neq i}^n [1 - P_{\text{дочерний узел } j}]),$$

где n – номер дочернего узла в графе для материнского узла;

$P_{\text{дочерний узел}}$ – вероятность реализации атаки через дочерний узел.

Риск в данной модели рассчитывается по следующим формулам:

а) для уязвимостей:

$$\overline{Risk}_{CVE_j}^{K,Ц,Д} = P_{CVE_j} * \bar{U}_{CVE_j},$$

где К, Ц, Д – означают влияние на конфиденциальность, целостность или доступность информации;

Р – вероятность эксплуатации уязвимости;

$\bar{U}$ – нормированный ущерб, который будет нанесен системе в случае успешной эксплуатации уязвимости.

б) для остальных узлов графа компонентов кибератак:

$$\overline{Risk}_{узел}^{K,Ц,Д} = \sum_{i=1}^N \overline{Risk}_{дочерний\ узел}^{K,Ц,Д} * W_{узел \rightarrow дочерний\ узел}.$$

Нормированный ущерб эксплуатации какой-либо из уязвимостей, в контексте данной реализации модуля, рассчитывается по следующей формуле:

$$\overline{U}_{K,Ц,Д} = \frac{CVSS_{CVE_j}^{K,Ц,Д}}{10},$$

где $CVSS_{CVE_j}^{K,Ц,Д}$ – CVSS-оценка по уровню влияния на конфиденциальность, целостность и доступность информации [1];

$$\phi\Phi_i(v) = \frac{1}{n!} \sum_{p \in (\text{перестановки } N)} [v(S_p(i) \cup \{i\}) - v(S_p(i))],$$

где $\phi\Phi_i(v)$ – вклад метрики $i \in \{K, Ц, Д\}$ в CVSS Base Score;

$S_p(i)$ – множество метрик, добавленных до i в перестановке p ;

$v(S)$ – функция расчета базовой CVSS-оценки при наличии только метрик из S .

После расчета маргинальных вкладов для каждой метрики требуется нормализация, что реализует следующая формула:

$$W_{K,Ц,Д} = \frac{\Phi_{K,Ц,Д}}{\Phi_K + \Phi_{Ц} + \Phi_{Д}}.$$

И результирующей является формула, которая позволяет рассчитать CVSS для каждой отдельной метрики безопасности информации:

$$CVSS_{CVE_j}^{K,Ц,Д} = CVSS_{CVE_j}^{Base\ Score} * W_{K,Ц,Д},$$

10 – коэффициент нормировки с учетом максимального значения CVSS.

Для разделения CVSS по уровню влияния на конфиденциальность, целостность и доступность информации используется метод Шепли, который позволяет распределить вклад каждой компоненты безопасности в базовую оценку CVSS [2]. Данный метод реализуется комплексом следующих формул:

где $CVSS_{CVE_j}^{Base\ Score}$ – базовая CVSS-оценка критичности уязвимости.

Данные метрики важны для качественного моделирования кибератак с помощью графа и предоставляют достаточный объем информации для последующего анализа.

Генерация ребер графа компонентов кибератак – данная задача является одной из наиболее важных в данном модуле в силу того, что полнота взаимосвязей между узлами графа влияет на качество анализа рисков. Для генерации ребер в данном модуле необходимо реализовать нейросетевую модель обработки естественного языка, которая даст возможность выявлять семантические связи между описаниями конкретных пар узлов, тем самым указывая на возможные связи между анализируемыми парами узлов. Нейросетевая модель основана на

объединении семантических векторов BERT (Bidirectional Encoder Representations from Transformers) и векторов ключевых слов TF-IDF (Term Frequency-Inverse Document Frequency), связка которых позволяет в полной мере обнаруживать взаимосвязи между узлами графа [3, 4].

Необходимо сформировать следующие дополнительные требования к алгоритмическому обеспечению. Данные требования подробно описывают варианты решения существующих проблем обеспечения киберустойчивости автоматизированных систем, учитывая динамику растущего числа угроз и их опасность. Далее приведены задачи, которые относятся к разработке алгоритмического обеспечения данного модуля:

- интеграция разнородных источников данных – ключевое требование, обеспечивающее поддержку различных источников данных о кибератаках, что должно достигаться стандартизацией формата загружаемых данных, а также автоматизированной установкой связей между новыми компонентами;

- работа в режиме реального времени - от алгоритмов модуля требуется поддержка постоянной эффективной работы в условиях, когда влияние киберугроз на информационное пространство быстро увеличивается. Данное требование позволит поддерживать данные в актуальном состоянии, обеспечивая эффективную работу остальных модулей системы;

- автоматизация – от модуля требуется высокий уровень автоматизации всех этапов его работы, сводя к минимуму ручную обработку данных, и тем самым ускоряя общее время реагирования на возникающие угрозы;

- поддержка графовой модели кибератак – алгоритмы должны поддерживать обработку и хранение данных в виде графа, где узлами являются компоненты кибератак, а ребра характеризуют взаимосвязи между этими компонентами, что обеспечивает наглядность модели угроз, поддержку анализа нелинейных сложных атак и быстрый поиск новых угроз;

- поддержка интеграции с другими модулями – от алгоритмов требуется такая структура, которая обеспечит быструю интеграцию с другими модулями системы, что требует использования протоколов обмена данными и возможности расширения функциональности без значительных изменений в существующих алгоритмах;

- точность и полнота информации – ключевое требование к алгоритмам модуля, гарантирующее отсутствие пропусков новых угроз, а также детализированную информацию о кибератаках, что критически необходимо для качественного проведения анализа.

Перечисленные требования важны для преодоления существующих ограничений противодействию новым угрозам кибербезопасности.

Структура алгоритмического обеспечения

Модуль централизованного сбора, обработки и хранения информации о компонентах кибератак представляет собой автоматизированное решение, которое дает возможность рассмотреть кибератаки на всех уровнях абстракции. Он обрабатывает следующие компоненты, которые содержит в себе атака:

- шаблоны сценариев атак;
- техники, применяемые в атаках;
- слабости архитектуры атакуемых систем;
- уязвимости атакуемых систем.

Данные компоненты дают достаточное количество информации о современной кибератаке, чтобы эффективно провести анализ рисков и выработать подходящие меры противодействия, даже если злоумышленник совершает многоэтапное нападение.

Главными задачами модуля являются сбор и обработка данных о компонентах кибератак, а также их хранение в графовой базе данных. Схематичное представление взаимосвязей между компонентами можно наблюдать на рис. 1.

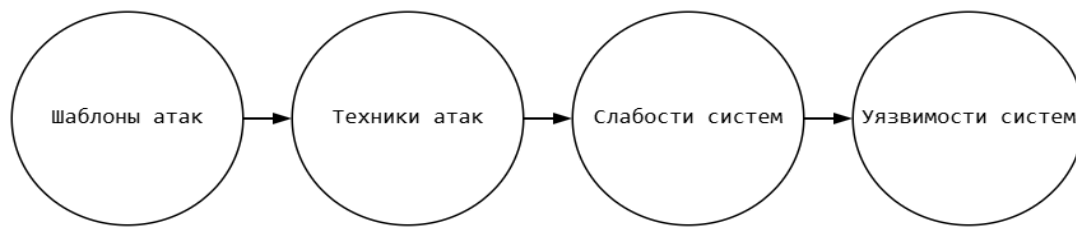


Рис. 1. Схема причинно-следственных связей между компонентами кибератаки

Данная модель кибератаки выделяет такую важную информацию, как:

- планы злоумышленника, которые отображены в шаблонах атак;
- набор техник злоумышленника, с помощью которых возможно выполнение его плана;
- слабости в системе, которые дают возможность атакующему применять определенные техники;
- конкретные уязвимости, которые порождаются слабостями в системе.

В результате, модуль централизованного сбора, обработки и хранения информации о компонентах кибератак, можно разделить на:

- алгоритмы сбора данных – алгоритмы должны обеспечить надежный и расширяемый функционал загрузки данных, необходимых для качественной работы, как настоящего модуля, так и других модулей, интегрированных в систему. Они должны поддерживать разные источники и давать возможность обеспечить полностью автоматизированный сбор данных о компонентах кибератак, что очень важно в условиях быстро развивающихся киберугроз;

- алгоритмы обработки данных – алгоритмы должны в полном объеме обрабатывать информацию, которая хранится в базе данных, с целью обогащения данных о киберугрозах, что обеспечит взаимодействующие модули качественной и полной информацией о кибератаках, что должно повысить их эффективность. В этом контексте алгоритмы должны с высокой точностью вычислять такие метрики, как нормированный ущерб, вероятность эксплуатации узлов, вероятность перехода от родительского узла к конкретному его дочернему узлу, а также риски реализации кибератак. Алгоритмы также должны обладать математической обоснованностью,

тем самым подтверждая корректность используемых в расчетах формул;

- алгоритм генерации ребер графа кибератак – алгоритм должен обеспечить быстрое и безошибочное сопоставление узлов графа между собой, тем самым связывая компоненты кибератак с разными типами, так как это напрямую влияет на полноту и эффективность обработки данных настоящим модулем и последующий анализ взаимодействующих модулей.

Процедуры сбора данных

1. Загрузка данных через JSON-файл – данный алгоритм необходим для универсальной загрузки данных из любого доступного источника. Формат JSON (JavaScript Object Notation) был выбран для загрузки данных из-за следующих его преимуществ [5]:

- кроссплатформенность – JSON поддерживается большинством наиболее популярных языков программирования, таких как Python, JavaScript, Java и C#, что дает возможность интегрировать модуль в различные системы;
- поддержка API – большинство современных API применяют JSON как основной метод передачи данных между клиентом и сервером;
- простота парсинга и сериализации данных – в большинстве популярных языков программирования есть встроенные, либо библиотечные средства для работы с JSON файлами.

Для успешной загрузки информации в грузовую базу данных требуется собрать необходимые данные и преобразовать их в JSON-файл по заданным шаблонам, в которых для всех типов данных необходимы уникальные идентификаторы и описание. Дополнительно для техник необходимы тактики, которым они соответствуют, а для

уязвимостей важными данными является ущерб. Блок-схема данного алгоритма вероятность эксплуатации и нормированный представлена на рис. 2:

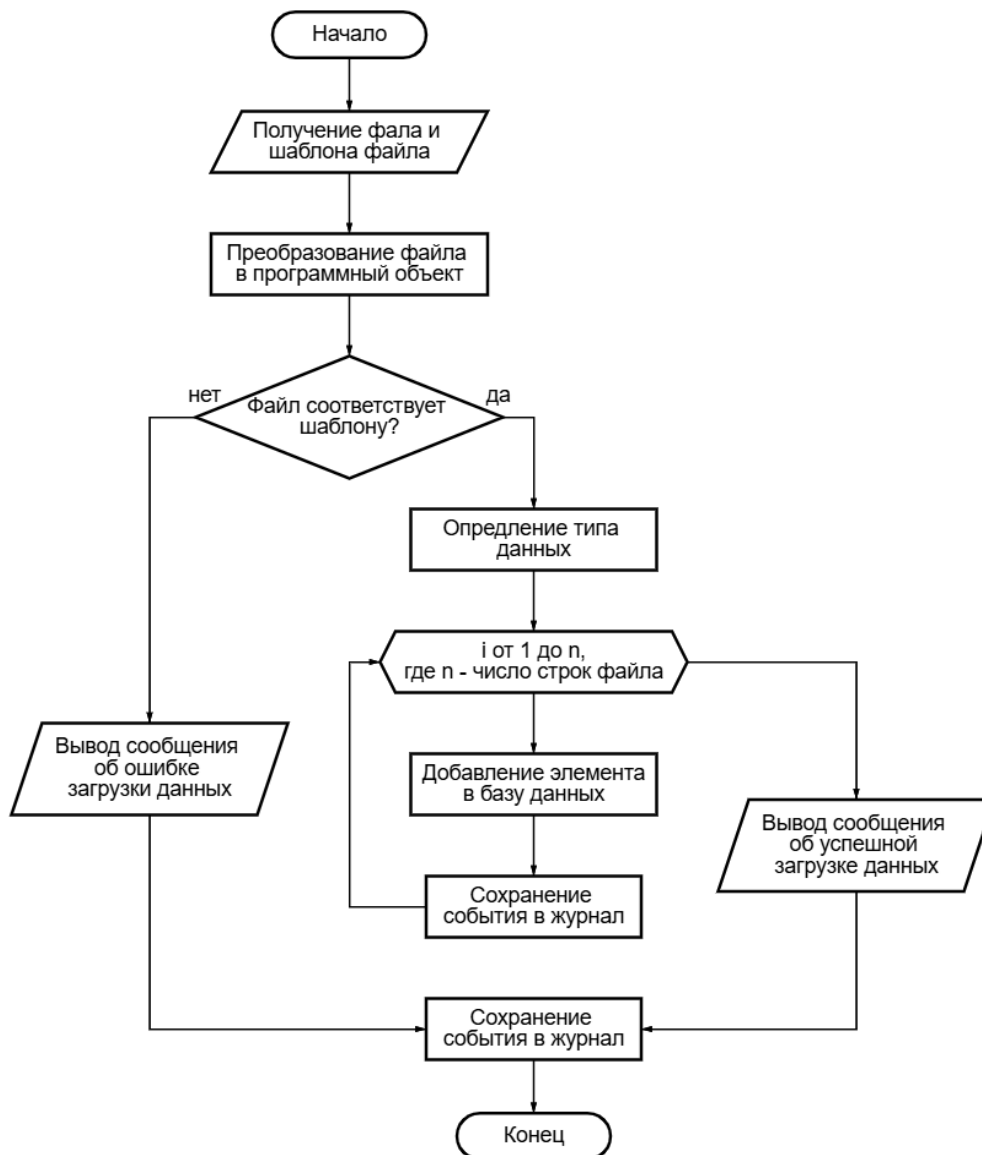


Рис. 2. Блок-схема алгоритма загрузки данных через JSON файл

Данный алгоритм полностью автоматизирует загрузку данных в хранилище информации о компонентах кибератак, предварительно проверяя структуру получаемого файла на соответствие шаблонам, а также сохранение всех событий, которые происходят во время

работы в журнал, что гарантирует контроль за работой модуля.

2. Автоматизированная загрузка данных из внешних источников – источниками данных были выбраны такие наиболее популярные и авторитетные ресурсы, как: NVD и MITRE:

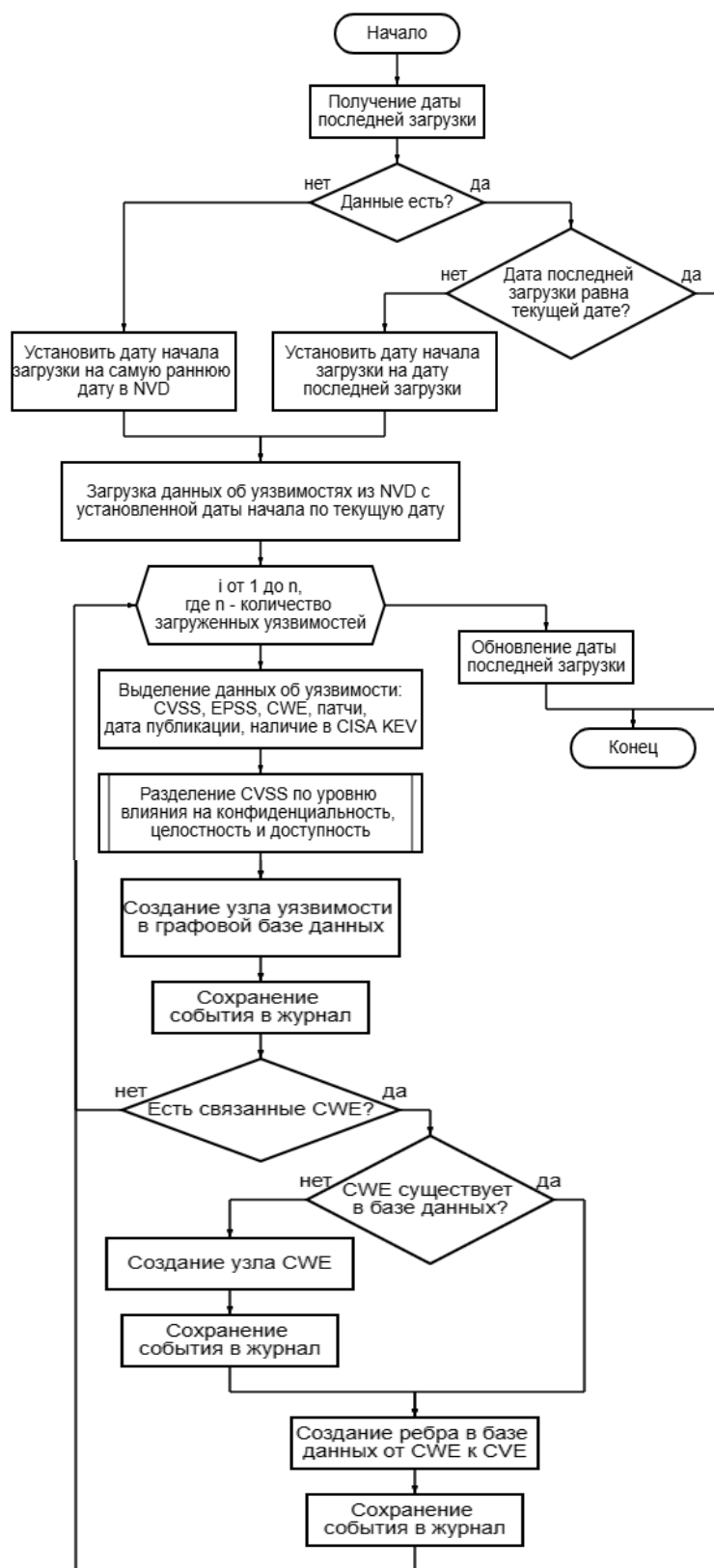


Рис. 3. Блок-схема алгоритма автоматизированной загрузки CVE из базы NVD

а) загрузка уязвимостей из базы данных NVD – NVD (National Vulnerability Database – база данных уязвимостей, которая содержит информацию о большинстве известных уязвимостей программного обеспечения. В этой базе данных каждой

уязвимости присваивается свой уникальный идентификатор CVE (Common Vulnerabilities and Exposures) [6]. Также для уязвимостей составляется список данных, в который включены: описание, уровень опасности (CVSS), дата обнаружения и публикации и

рекомендации по устранению. Еще одним наиболее важным для автоматизации преимуществом NVD является наличие открытого API, что значительно упрощает алгоритм и ускоряет процесс загрузки и обновления данных.

В начале работы алгоритм должен проверять актуальность существующих данных об уязвимостях, что выполняется путем сверки последней даты загрузки. После чего из NVD загружается информация о новых уязвимостях, которая накапливается в массивы данных, включая в себя такие важные составляющие CVE, как: уникальный идентификатор, описание уязвимости, дату ее публикации, оценку CVSS и существующие исправления. Кроме того, происходит обогащение данных о CVE ее оценкой EPSS, характеризующей вероятность эксплуатации уязвимости за ближайшие 30 дней, а также наличие уязвимости в списке CISA KEV (Cybersecurity and Infrastructure Security Agency Known Exploited Vulnerabilities), что позволяет выявить наиболее популярные в эксплуатации уязвимости [7, 8].

Одним из этапов является алгоритм разделения CVSS по уровню влияния на конфиденциальность, целостность и доступность, что дает возможность проводить не только общую оценку критичности атаки, но и ее угрозу основным свойствам безопасности информации. Представление алгоритма в виде блок-схемы изображено на рис. 3

Также важным достоинством алгоритма является то, что из NVD загружаются данные о взаимосвязях уязвимостей со слабостями CWE, которые эксперты выявили в ходе исследований. После любого действия, связанного с изменением информации в базе данных, информация о нем обязательно сохраняется в журнал, что значительно повышает безопасность.

б) загрузка слабостей из MITRE CWE - CWE (Common Weakness Enumeration) - система классификации слабостей программного обеспечения, представленная в виде списка типовых слабых мест архитектуры. В этой базе данных каждому

типу уязвимости присваивается уникальный идентификатор CWE с ее подробным описанием, распространенностью, а также рекомендациями по предотвращению появления таких слабостей в программном обеспечении.

Наиболее важными достоинствами CWE является структурированность и широкая применимость, что предоставляет такие возможности в обеспечении безопасности информации, как использование на этапах: разработки, тестирования и анализа программного обеспечения. Главным преимуществом CWE в модели кибератак принято считать, что слабости в программном обеспечении помогают выявлять не только конкретные инциденты безопасности, как это делает CVE, но и понимать причины, из-за которых данные уязвимости возникли.

В начале работы алгоритм осуществляет проверку актуальности данных. Так как MITRE публикует наиболее актуальные данные в виде файлов на своем сайте, то проверка на обновление информации должна проводиться путем сопоставления хэша файлов (уникальных строк символов, являющихся цифровыми отпечатками содержимого файлов). Если хэш последней загрузки совпадает, то из этого следует, что содержимое файла CWE MITRE не менялось, и обновление слабостей графовой базы данных не требуется.

В случае же, когда файла предыдущей загрузки нет (загрузка слабостей в графовую базу данных происходит впервые) или когда хэш файлов не совпал, происходит загрузка данных и парсинг (сбор и структурирование информации, содержащейся в файле), при котором формируются такие поля слабости, как: уникальный идентификатор CWE, описание слабости и распространенность. Кроме обработки этой информации происходит и обновление связей между CWE и CVE или техниками MITRE ATT&CK. В конце успешной загрузки данных хэш файла последней загрузки обновляется. Блок-схема данного алгоритма изображена на рис. 4.

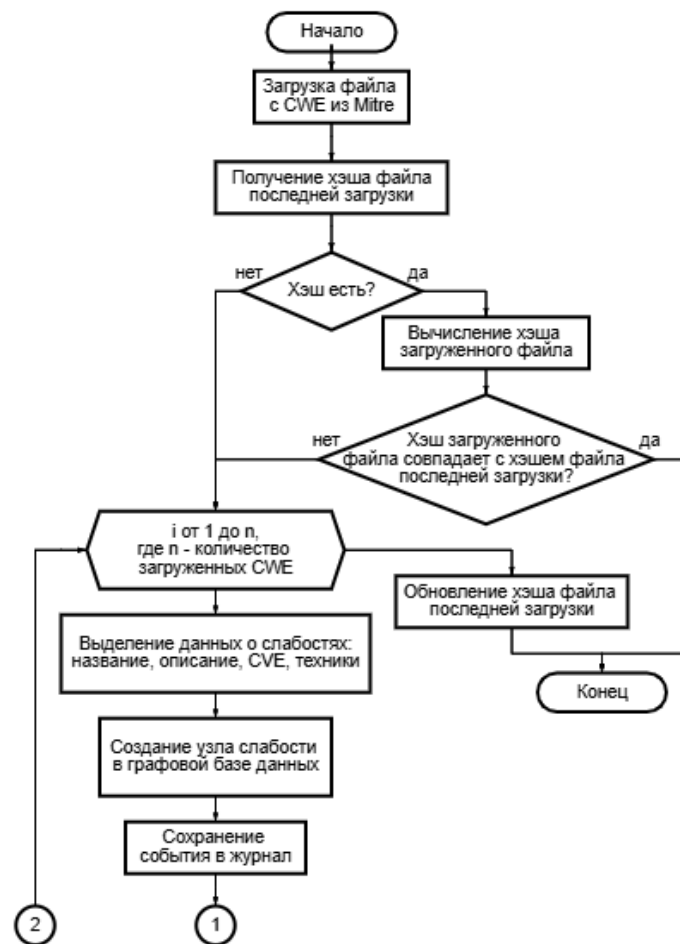


Рис. 4. Блок-схема алгоритма автоматизированной загрузки слабостей из MITRE CWE

в) загрузка техник из MITRE ATT&CK - MITRE ATT&CK – это база данных включающая в себя информацию о тактиках и техниках, которые злоумышленник использует на различных этапах кибератаки. В информацию о техниках входят такие данные, как: уникальный идентификатор, подробное описание, связанные тактики, а также методы обнаружения и меры защиты, которые помогают предотвратить или ослабить воздействие кибератаки на систему.

Важным преимуществом использования техник данной базы знаний является высокие структурированность и степень детализации, так как описываются все этапы кибератак, начиная от разведки и первоначального доступа и заканчивая эксfiltrацией данных и деструктивным воздействием на систему. Наличие информации о связанных тактиках позволяет в будущем сформировать граф сценариев кибератак, который сможет моделировать реалистичное и точное

поведение злоумышленников, в отличие от современных популярных методов, что подходит к этому избыточно линейно. Такие важные достоинства делают MITRE ATT&CK наиболее приоритетным инструментом для моделирования и анализа кибератак.

Из-за того, что данной базой данных владеет MITRE, то актуальность загруженной информации о техниках, подобно предыдущему алгоритму, проверяется при помощи сверки хэшей загруженного ранее файла и файла с последней информацией на сайте MITRE. Процесс обновления или же первоначальной загрузки данных схож с загрузкой CWE, но важным отличием является создание взаимосвязей, которые выявили эксперты MITRE, между обновляемой техникой и шаблонами сценариев CAPEC или слабостями CWE.

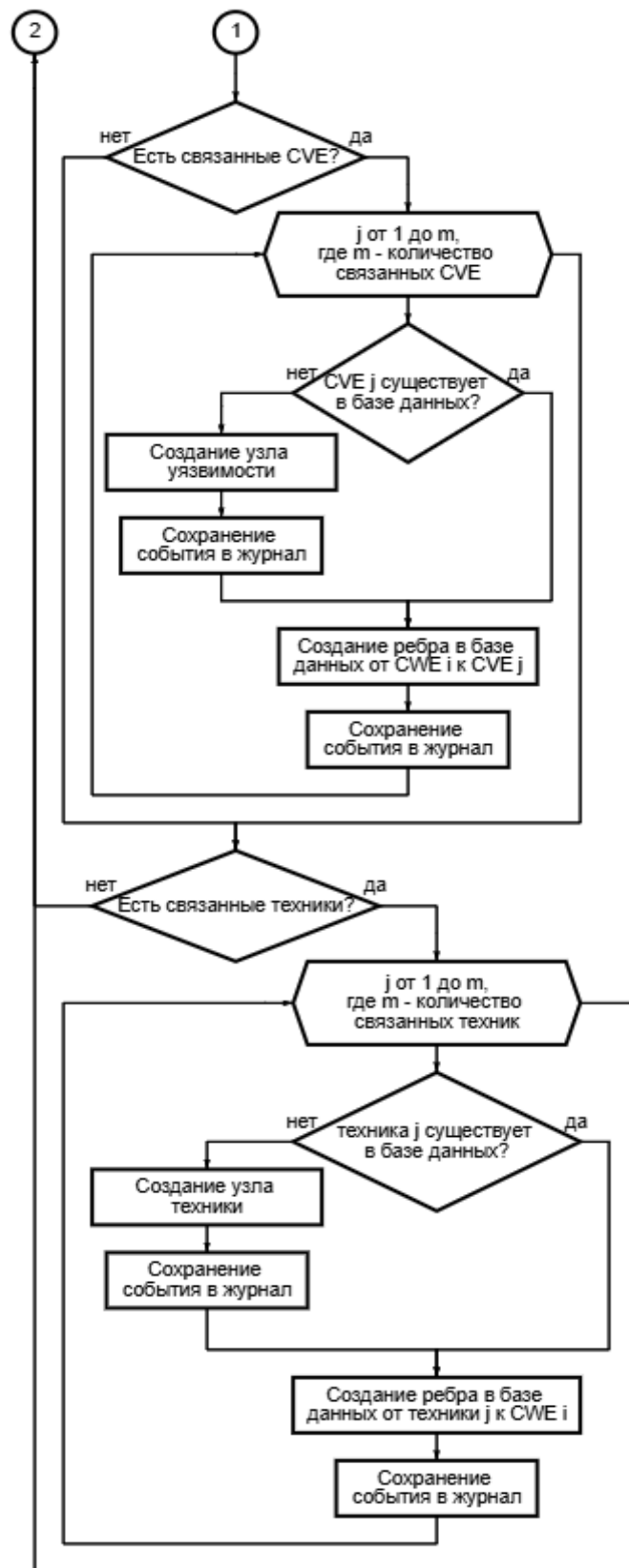


Рис. 4. Продолжение

В конце успешного завершения обеспечения корректную проверку формирования новых данных хэш актуальности при следующем запуске загружаемого файла сохраняется с целью

алгоритма. Блок-схема алгоритма представлена на рис. 5.

г) загрузка шаблонов сценариев из MITRE CAPEC – CAPEC (Common Attack Pattern Enumeration and Classification) - база знаний, созданная для классификации атак на основе реальных угроз. В CAPEC для каждого отдельного шаблона сценариев атаки описываются такие данные, как его уникальный идентификатор, описание целей атакующего, последовательности его действий и предпосылок для их реализации.

Главным преимуществом этой базы данных является то, что она фокусируется на сценариях атак, применяемых против различных систем и технологий. Это позволяет использовать CAPEC для объединения различных техник кибератак,

что были интегрированы в данный модуль ранее, тем самым моделируя множества сценариев атак, реализуемых злоумышленниками, основываясь на их поведении и целях.

Включение шаблонов сценариев кибератак из базы знаний CAPEC обеспечивает следующие возможности:

- моделирование поведения злоумышленника на основе сценариев кибератак;
- связь между тактиками злоумышленника, а соответственно, и его техниками;
- поддержка анализа современных сложных многоэтапных атак, включая нелинейные сценарии развития.

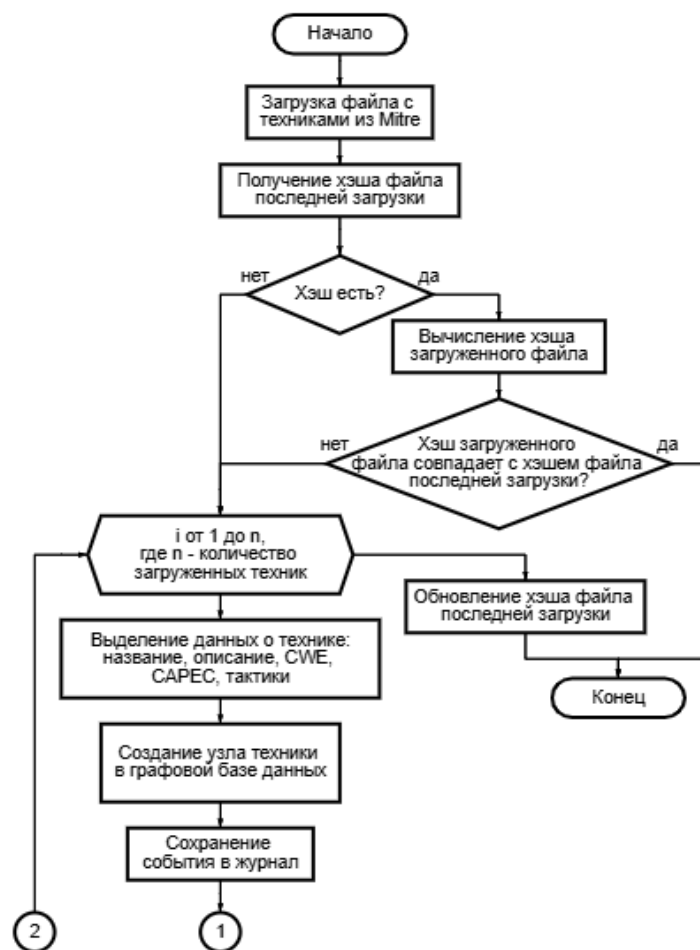


Рис. 5. Блок-схема алгоритма автоматизированной загрузки техник из MITRE ATT&CK

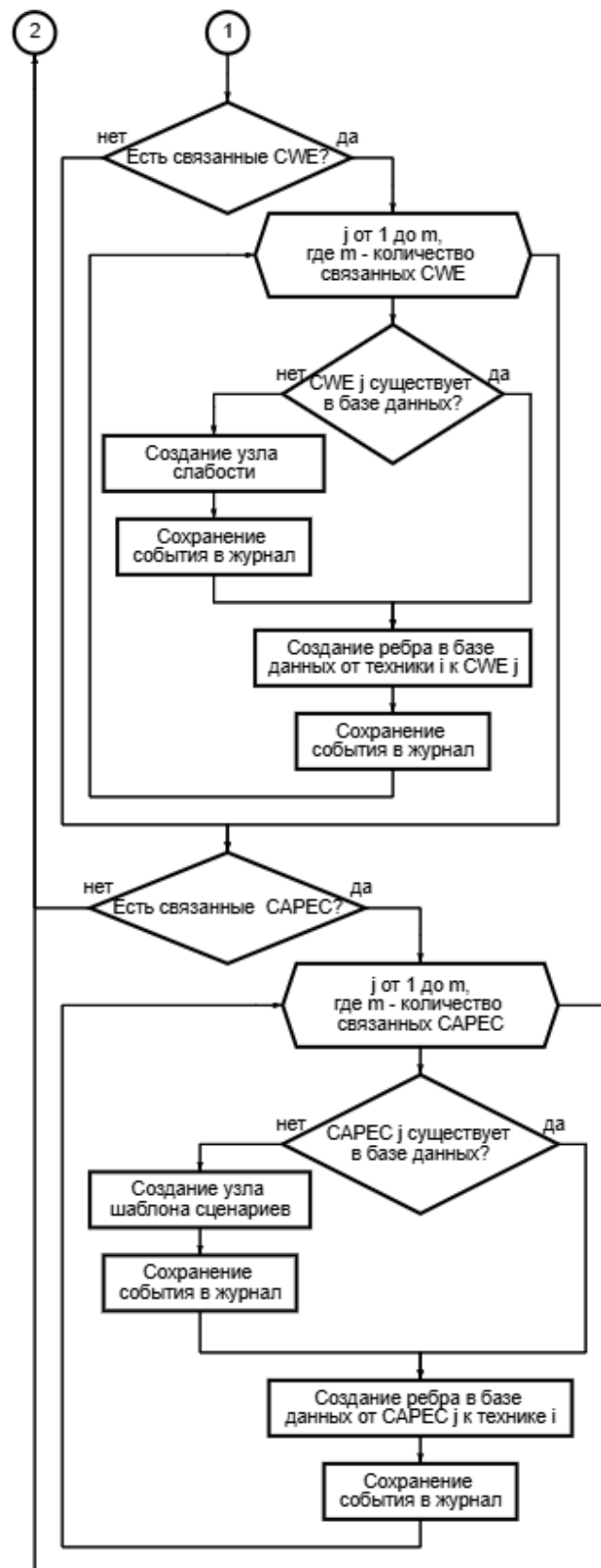


Рис. 5. Продолжение

Для автоматизированной загрузки информации о шаблонах сценариев кибератак из MITRE CAPEC используется аналогичный подход, как и при работе с CWE и техниками АТТ&СК. Алгоритм начинается работу с проверки актуальности

существующих данных, сравнивая хэш ранее загруженного файла с хэшем последней версии, что доступна на официальном сайте MITRE CAPEC. В случае, если текущие данные устарели или же загрузка выполняется впервые, запускается процесс загрузки и парсинга файла, предоставляемого MITRE, в результате чего формируются такие поля о шаблонах

сценариев кибератак, как: уникальный идентификатор CAPEC, название и подробное описание шаблона, а также взаимосвязи с соответствующими техниками MITRE ATT&CK.

После успешного завершения загрузки и обработки данных, хэш нового файла сохраняется в локальное хранилище. Блок-схема алгоритма представлена на рис. 6.

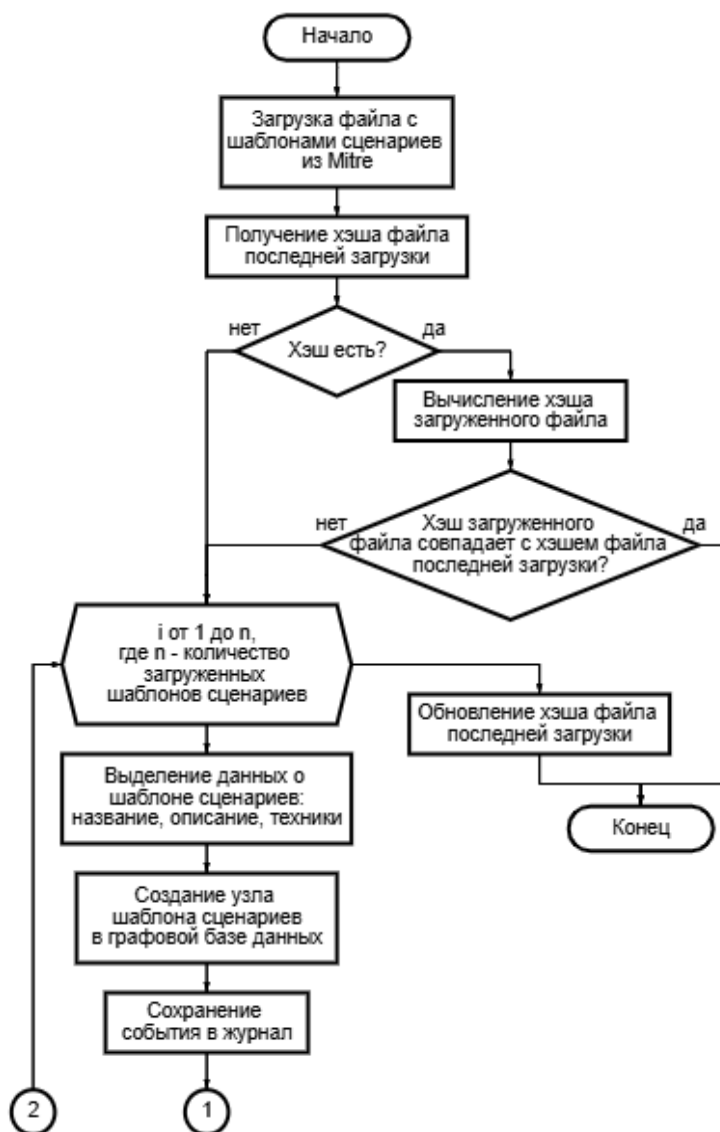


Рис. 6. Блок-схема алгоритма автоматизированной загрузки шаблонов сценариев из MITRE CAPEC

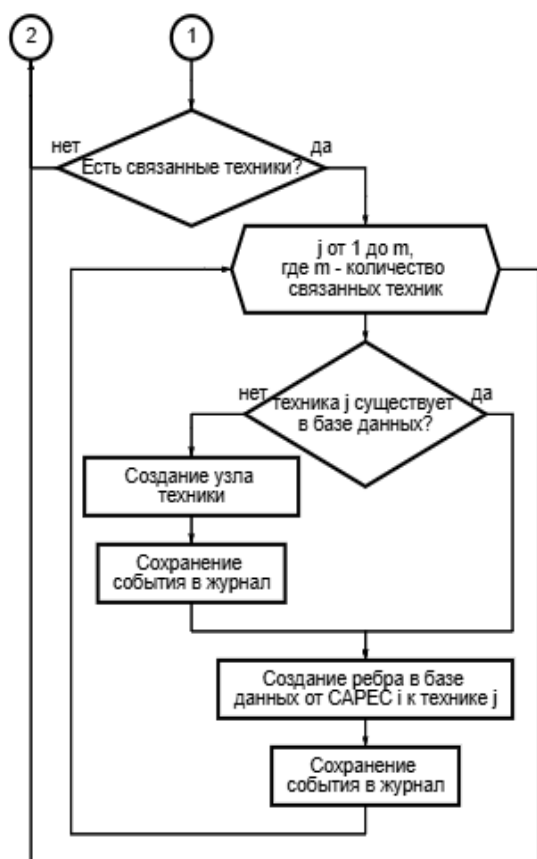


Рис. 6. Продолжение

е) автоматическое обновление графовой базы данных – алгоритм автоматического обновления графовой базы данных необходим для обеспечения актуальности информации о компонентах кибератак. Он играет ключевую роль в выполнении одного из самых важных требований к алгоритмическому обеспечению, а именно работы системы в режиме реального времени.

Данный алгоритм отвечает за периодический запуск комплекса алгоритмов загрузки данных из внешних источников, которые были приведены ранее, тем самым обеспечивая постоянное обновление актуальных данных о кибератаках без необходимости ручного вмешательства со стороны пользователя. Выполнение таких задач позволяет системе оперативно реагировать на новые кибератаки, своевременно дополняя появившиеся данные.

Данный алгоритм имеет гибкую структуру, так как дает возможность пользователю самому выбрать временной интервал, с периодичностью которого будет

происходить обновление базы данных. Данный интервал задается в минутах, обеспечивая возможность выбора большого спектра частот проверки обновлений. После ввода значения интервала и между обновлениями алгоритм находится в режиме ожидания.

По истечении заданного временного интервала алгоритм активирует ранее разработанные алгоритмы:

- автоматизированной загрузки уязвимостей из NVD;
- автоматизированной загрузки слабостей из MITRE CWE;
- автоматизированной загрузки техник из MITRE ATT&CK;
- автоматизированной загрузки шаблонов сценариев из MITRE CAPEC.

Из-за того, что в каждом из этих алгоритмов заложен функционал проверки актуальности уже имеющихся данных, данный подход в алгоритме является наиболее эффективным. При выявлении обновлений алгоритмами производится загрузка этих данных, их парсинг и обогащение, а также обновление связей между различными компонентами кибератак. Таким образом, алгоритм автоматического обновления графовой базы данных позволяет поддерживать модель кибератак в актуальном состоянии, что особенно важно в условиях быстро меняющихся угроз.

После завершения цикла обновления алгоритм снова переходит в режим ожидания, тем самым начиная новый отсчет времени. Таким образом, процесс обновления данных является бесконечным и выполняется пока общая система находится в рабочем состоянии. Блок-схема алгоритма представлена на рис. 7.

В результате построены алгоритмы сбора данных, которые реализуют надежную, автоматизированную и гибкую систему загрузки и обновления информации о компонентах кибератак в графовой базе данных. Эти алгоритмы позволяют:

- поддерживать актуальность информации в режиме реального времени;
- интегрировать разнородные источники данных;

- обеспечивать полноту и точность модели кибератак;
- поддерживать дальнейший анализ рисков и построение защитных мер на основе качественной и структурированной информации.

Алгоритмы сбора данных являются основополагающей частью функциональности настоящего модуля и системы в целом.

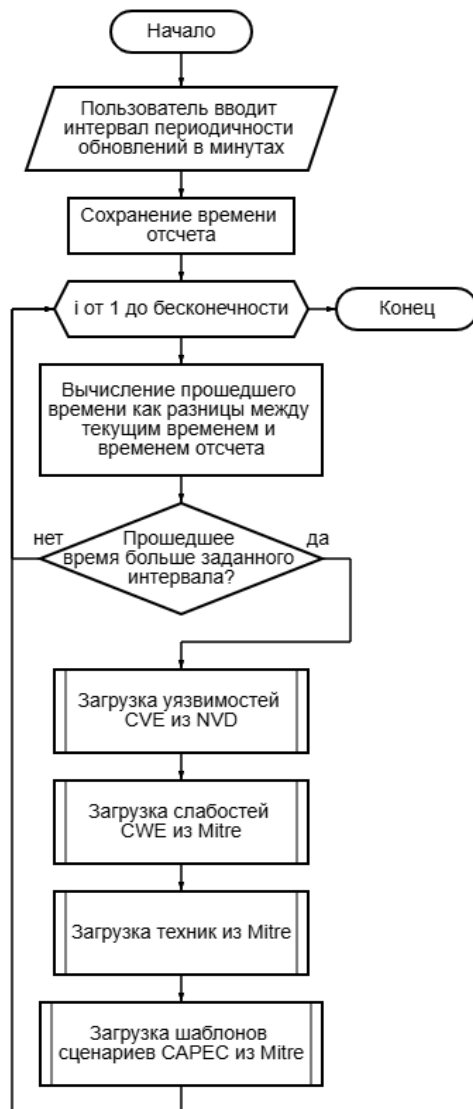


Рис. 7. Блок-схема алгоритма автоматического обновления графовой базы данных

Процедуры обработки данных

Алгоритмы обработки данных в модуле централизованного сбора, обработки и хранения информации о компонентах кибератак представляют высокую значимость. Данные, которые загружаются из внешних источников, имеют обобщенный

вид и предназначены больше для обзора, чем для полноценного управления рисками, а их обработка и вычисление дополнительных метрик безопасности информации значительно обогащают базу данных. Далее будут рассмотрены алгоритмы, необходимые для полноценного функционирования модуля.

1. Алгоритм разделения CVSS по уровню влияния на конфиденциальность, целостность и доступность информации - в данном алгоритме реализован метод Шепли в контексте распределения вклада каждой метрики безопасности информации в базовую оценку CVSS, что существенно расширяет возможности анализа рисков кибератак, позволяя выявлять только самые важные объекты для защиты.

Алгоритм получает на вход версию и вектор CVSS, после чего происходит цикл со всевозможными перестановками метрик конфиденциальности, целостности и доступности информации. Для каждой такой коалиции происходит расчет базовой оценки CVSS с конкретной метрикой и ее отсутствием в коалиции, и наконец вычисляется маргинальный вклад данной метрики, как разница между базовыми оценками CVSS, рассчитанными до и после добавления этой метрики в коалицию.

После того, как для каждой метрики и перестановки рассчитан свой вклад, происходит усреднение этого вклада в контексте каждой из трех метрик: конфиденциальности, целостности и доступности, путем деления этого вклада на количество перестановок.

И в результате отнормирования вклада каждой метрики делением на сумму вкладов всех метрик, появляется возможность найти значение CVSS, которое влияет на определенную метрику безопасности информации, путем умножения базового значения CVSS, рассчитанного по начальному вектору CVSS, на нормированный вклад метрики в это самое базовое значение.

Наглядное отображение данного алгоритма изображено в виде блок-схемы на рис. 8.

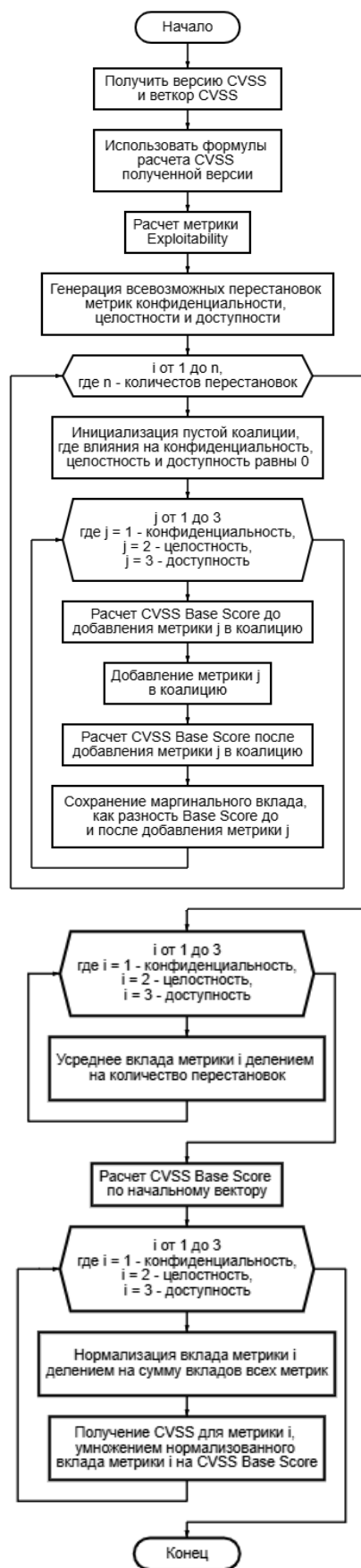


Рис. 8. Блок-схема алгоритма разделения CVSS по уровню влияния на конфиденциальность, целостность и доступность информации

2. Алгоритм расчета вероятности успешной эксплуатации узла в ходе атаки. Вероятность успешной эксплуатации узла в ходе атаки является важным значением для анализа рисков, так как именно она позволяет определить наиболее вероятные направления кибератак.

У уязвимостей CVE, как наименее абстрактных и наиболее распространенных по количеству успешной эксплуатации элементов рассматриваемой модели кибератак, имеется возможность статистического расчета вероятности эксплуатации. Так, из большого количества обнаруженных эксплуатаций уязвимостей в различных системах, а также информации о наличии в них эксплойтов, возможно определение статистической вероятности эксплуатации той или иной уязвимости, что и было реализовано для CVE системой EPSS, которая позволяет оценить вероятность эксплуатации уязвимости в ближайшие 30 дней.

Зная вероятность эксплуатации уязвимостей, которые являются фундаментальными элементами графовой модели кибератак, можно осуществить агрегирование данных вероятностей на более абстрактные уровни модели. Таким образом, данный алгоритм решает задачу расчета вероятностей эксплуатации слабостей и техник, а вероятности реализации шаблонов атак не представляют интереса в силу того, что модуль генерации сценариев кибератак рассматривает данные шаблоны более подробно и с высокой точностью.

Работа алгоритма начинается с получения конкретного родительского узла и всех его дочерних узлов, у которых уже имеются вычисленные вероятности, что гарантируется шаблонами загружаемых файлов в алгоритмах сбора данных рассматриваемого модуля.

После получения всех необходимых данных выполняется этап вычисления вероятности эксплуатации узла, результатом которого должна быть вероятность того, что какой-либо один из дочерних узлов будет проэксплуатирован в ходе атаки. Алгоритм совершает перебор дочерних узлов и для каждого вычисляет вероятность, что именно этот узел будет проэксплуатирован, а все

остальные нет. Результат полученных вероятностей суммируется и тем самым рассчитывает вероятность, что только один из дочерних узлов будет проэксплуатирован. Блок-схема алгоритма расчета вероятности успешной эксплуатации узла в ходе атаки изображена на рис. 9.

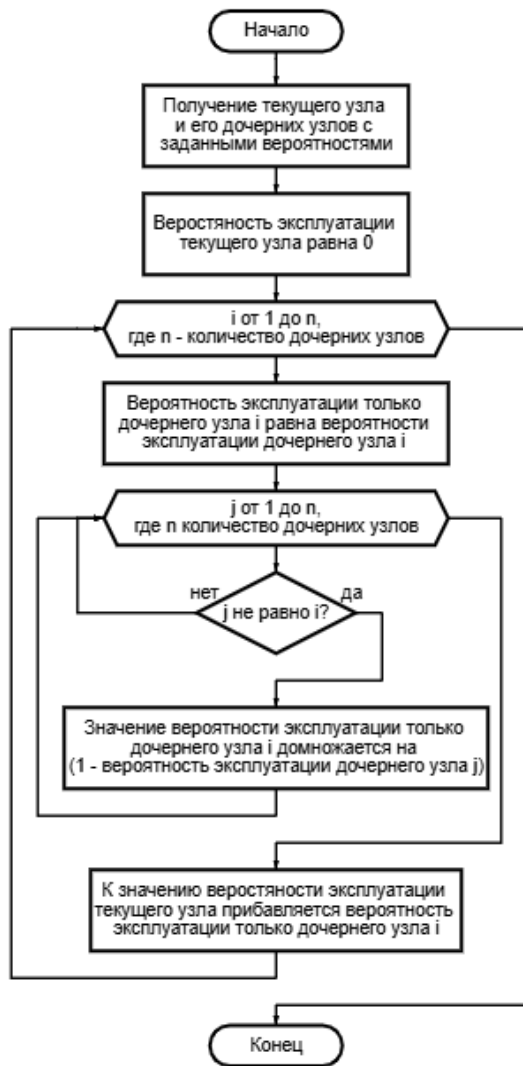


Рис. 9. Блок-схема алгоритма расчета вероятности успешной эксплуатации узла графа в ходе атаки

3. Алгоритм расчета вероятности выбора злоумышленником следующего дочернего узла. Расчет вероятности применения дочернего узла в контексте конкретного узла следующего уровня абстракции в модели кибератак одно из самых важных требований информационного обеспечения. Это значение описывает логику злоумышленника в том, что он будет использовать только те техники и уязвимости, которые с

наибольшей вероятностью смогут обеспечить успех атаки и достижение поставленной цели атакующим. В конкретной атаке от любого узла вероятность перехода к какому-либо дочернему узлу равна 100%, поэтому алгоритм реализует расчет вероятности как пропорцию вероятности конкретного дочернего узла к сумме вероятностей всех дочерних узлов.

Алгоритм начинает работу с получения родительского узла в контексте кибератаки, целевого дочернего узла, вероятность перехода к которому нужно рассчитать, а также остальных дочерних узлов с вероятностями их эксплуатации. Далее происходит расчет суммарной вероятности эксплуатации всех дочерних узлов, данное значение может принимать значение больше 1, так как оно используется только для определения пропорции вероятности эксплуатации целевого дочернего узла к сумме всех дочерних узлов.

Заключительным этапом алгоритма является нахождение частного вероятности эксплуатации целевого дочернего узла к сумме вероятностей эксплуатации остальных дочерних узлов, что и является вероятностью применения дочернего узла в ходе реализации атаки. Визуально данный алгоритм изображен в виде блок-схемы на рис. 10.

4. Алгоритм расчета рисков является одним из фундаментальных алгоритмов в контексте обеспечения информационной безопасности, поскольку дает возможность осуществлять количественную оценку элементов графа кибератак, учитывая при этом вероятности возникновения инцидента и ущерб, который он может причинить системе. При этом, не учитывая риск, невозможно точно ранжировать угрозы и тем самым вырабатывать эффективные меры противодействия и обоснованные решения по обеспечению безопасности информации.



Рис. 10. Блок-схема алгоритма расчета вероятности перехода к дочернему узлу графа

Так как данный алгоритм расчёта рисков применяется не только к конкретным уязвимостям, но также и к слабостям, техникам и шаблонам атак, то он обеспечивает возможность проводить анализ не только с технической стороны реализации кибератаки, но и с организационной стороны, учитывая условия, при которых атака может быть совершена злоумышленником. Данный подход позволяет сосредоточить внимание на наиболее опасных угрозах безопасности информации, что повышает эффективность

организационно-правового управления рисками информационной безопасности.

Данный алгоритм рассчитывает риски для следующих узлов:

- уязвимости – значения риска рассчитывается как произведение вероятности эксплуатации и нормированного ущерба. В рассматриваемой графовой модели риск уязвимости является фундаментальным значением и все остальные риски графа зависят от него;

- слабости и техники - для узла риск рассчитывается как взвешенная сумма рисков дочерних узлов, то есть суммируются произведения риска дочерних узлов на вероятности выбора злоумышленником этих узлов. Таким образом происходит агрегация рисков к более абстрактным уровням модели.

- шаблоны атак - так как шаблоны описывают возможные сценарии кибератак, то риск такого узла рассчитывается на основе рисков сценариев. Алгоритм генерирует сценарии шаблона, а также рассчитывает их риски при помощи модуля генерации сценариев кибератак. После получения необходимых данных, алгоритм суммирует риски каждого из сценариев атаки, тем самым получая риск шаблона атаки.

Результатом работы алгоритма является рассчитанный риск для каждого из доступных типов узлов графовой модели кибератак. Полученные данные важны для взаимосвязанных алгоритмов и модулей разрабатываемой системы, ведь они позволяют ранжировать узлы по уровню их опасности.

Блок-схема алгоритма расчета рисков изображена на рис. 11.

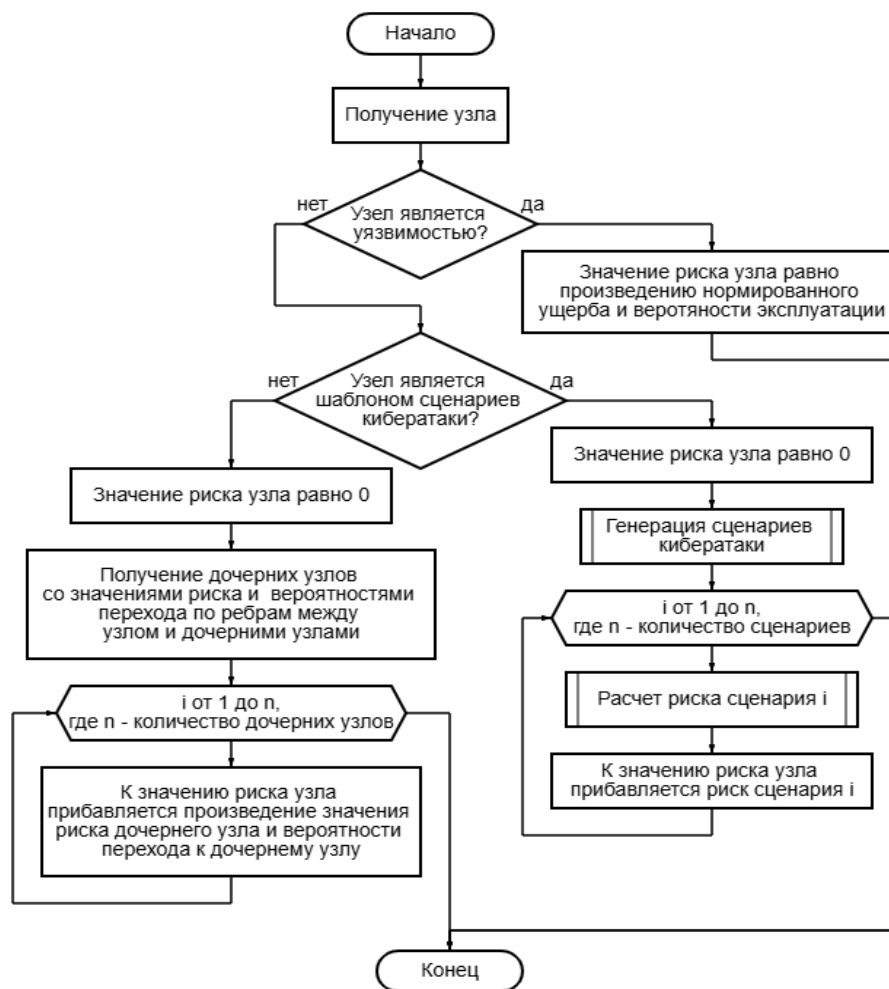


Рис. 11. Блок-схема алгоритма расчета рисков

Процедуры генерации ребер графа кибератак

Полнота компонентов графа кибератак является неотъемлемым условием для получения точных результатов анализа рисков, а также для промежуточных вычислений, производимых другими алгоритмами системы. Обеспечение полноты данных в графовой базе данных является одной из основных задач информационного обеспечения, разработанного для данной системы автоматизированной генерации мер и сценариев противодействия кибератакам.

Алгоритм генерации ребер графа кибератак в своей работе использует подход оценки ансамблированного сходства между векторами BERT, которые указывают на семантические данные об узле, а также векторами TF-IDF, описывающие ключевые термины, применяемые в

При работе алгоритм обеспечивает генерацию ребер графа кибератак между следующими парами узлов:

- между слабостями и уязвимостями;
- между техниками и слабостями;
- между шаблонами атак и техниками.

Для каждой из пар узлов происходит перебор узлов для всякой пары, тем самым внутри пары объединяются новые пары, но уже между узлами, а не между типами узлов. Для каждой пары узлов происходит расчет смысловых векторов BERT и векторов ключевых слов TF-IDF. Эти векторы сравниваются между собой и вычисляется косинусное сходство, после чего данные объединяются в ансамбль, где сходство векторов BERT имеет 70 % от объединенного значения, а остальные 30 % имеет сходство векторов TF-IDF. Данное соотношение подобрано так, чтобы семантика в контексте сравнения описаний имела доминирующую роль, но ключевые

слова, применяемые в описаниях, все же учитывались в конечном результате. Также точность таких пропорций между косинусным сходством векторов подтверждается в ходе множества разработок систем анализа естественного языка.

После вычисления ансамблированного сходства алгоритм совершает проверку на условие, превышает ли оно порог в 80 процентов. Если значение выше порогового, то происходит создание нового ребра в графе между парой рассматриваемых узлов и внесение данных о созданном ребре в журнал. Если же значение вычисленного сходства меньше порогового значения, то алгоритм пропускает данную пару.

Пороговое значение было подобрано экспериментально, ибо в случаях, когда значение было выше 80 процентов происходил пропуск важных связей между узлами графа кибератак, в свою же очередь значение ниже 80 процентов генерировало большое количество ребер для пар узлов, связь между которыми слабо обоснована и тем самым снижает целостность модели.

Алгоритм обеспечивает полноту графа кибератак, тем самым гарантируя наиболее эффективный процесс анализа рисков и точность сформированной модели кибератак. Наглядное представление данного алгоритма изображено в виде блок-схемы на рис. 12.

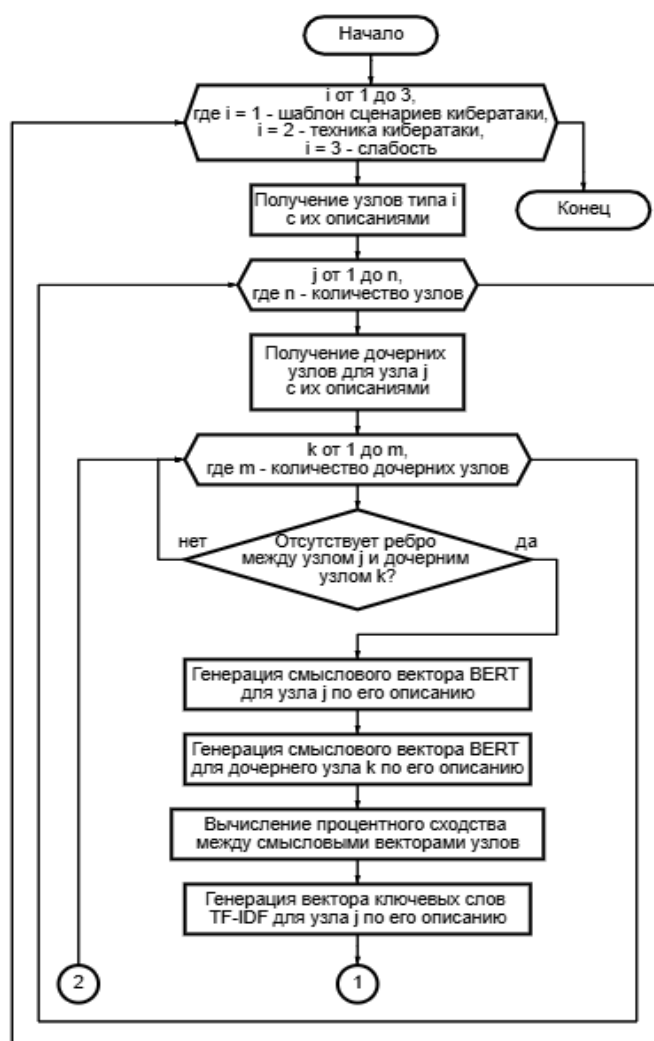


Рис. 12. Блок-схема алгоритма генерации ребер графа кибератак

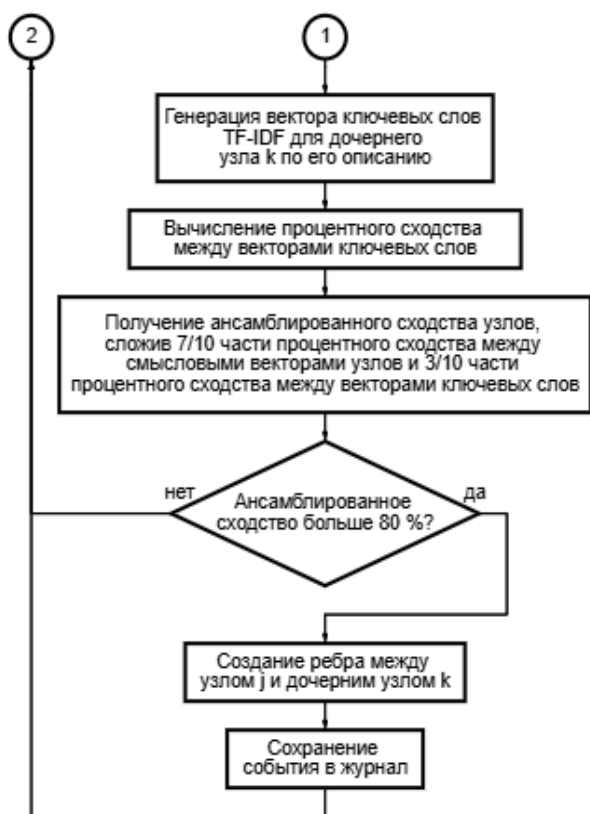


Рис. 12. Продолжение

Заключение

В результате были сформированы ключевые требования к алгоритмическому обеспечению модуля централизованного сбора, обработки и хранения информации о компонентах кибератак, а также рассмотрены требования методического обеспечения для автоматизированной генерации мер и сценариев противодействия кибератакам. Во исполнение этих требований методического обеспечения были сформулированы и решены следующие задачи:

- формирование графовой модели кибератак - для решения данной задачи был разработан как универсальный алгоритм для загрузки данных через JSON файл на основе разработанных шаблонов, так и узконаправленные алгоритмы агрегации данных из таких внешних источников как: NVD для загрузки уязвимостей CVE, MITRE для загрузки слабостей программного обеспечения CWE, техник MITRE ATT&CK и шаблонов атак CAPEC;

- обработка данных графовой модели - задача была решена разработкой комплекса

алгоритмов, позволяющих рассчитать такие веса узлов, как нормированный ущерб, вероятность эксплуатации и риск информационной безопасности. Для ребер графа был разработан алгоритм расчета вероятности перехода от узла более высокого уровня иерархии к конкретному дочернему узлу;

- генерация связей между различными типами узлов графа - задачу решает алгоритм, подразумевающий в своей реализации нейросетевую модель, которая будет на основе анализа семантической взаимосвязи и ключевых слов между описаниями узлов выбирать наиболее релевантные связи, обеспечивая точность и полноту графовой модели.

Дополнительные требования к алгоритмическому обеспечению были сформированы на основе проведенного исследования современных киберугроз и недостатков существующих средств противодействия им. Они включают в себя следующие пункты:

- интеграция разнородных источников данных;
- поддержка работы в режиме реального времени;
- высокий уровень автоматизации;
- возможность интеграции с другими модулями системы;
- обеспечение точности и полноты информации.

Предъявленные к алгоритмам требования были полностью реализованы, что обеспечило модулю высокую функциональную целостность, а также адаптивность к стремительно развивающемуся киберпространству и угрозам, циркулирующим в нем.

В ходе работы была полностью сформирована разработанная структура модуля, которая включает в себя такие части как:

- алгоритмы сбора данных, позволяющие загружать информацию в графовую базу данных как в ручном, так и в автоматическом режиме, обеспечивая тем самым актуальность и полноту данных;

- алгоритмы обработки данных, реализующие вычисления важных метрик графа;

- алгоритм генерации ребер графа, использующий методы машинного обучения (BERT + TF-IDF) для установления новых взаимосвязей между компонентами графа кибератак, что значительно повышает полноту модели и её аналитическую ценность.

Таким образом, было разработано алгоритмическое обеспечение, которое доведенот до программной реализации, объединяющей в себе автоматизированный сбор, анализ, обогащение и хранение информации о компонентах модели кибератак. Благодаря этому возникнет такие важные преимущества как: оперативное реагирование на новые угрозы и анализ рисков, необходимый для последующей генерации эффективных мер противодействия.

В результате разработанный модуль централизованного сбора, обработки и хранения информации о компонентах модели кибератак обеспечивает основу для последующей автоматизированной генерации мер и сценариев противодействия кибератакам.

Список литературы

1. CVSS v4.0 Документация. URL: <https://www.first.org/cvss/specification-document> (дата обращения 20.08.2025).
2. Теория игр: Модель Шепли. URL: <https://chiefauto.ru/blog/teoriya-igr-model-shepli-i-ee-primenenie-v-marketinge> (дата обращения 20.08.2025).
3. BERT (языковая модель). URL: [https://neerc.ifmo.ru/wiki/index.php?title=BERT_\(%D1%8F%D0%B7%D1%8B%D0%BA%D0%BE%D0%B2%D0%B0%D1%8F_%D0%BC%D0%BE%D0%B4%D0%B5%D0%BB%D1%8C\)](https://neerc.ifmo.ru/wiki/index.php?title=BERT_(%D1%8F%D0%B7%D1%8B%D0%BA%D0%BE%D0%B2%D0%B0%D1%8F_%D0%BC%D0%BE%D0%B4%D0%B5%D0%BB%D1%8C)) (дата обращения 20.08.2025).
4. TF-IDF (Term Frequency-Inverse Document Frequency). URL: <https://www.geeksforgeeks.org/understanding-tf-idf-term-frequency-inverse-document-frequency/?ysclid=mcmzciujto168940424> (дата обращения 20.08.2025).
5. Понятие JSON и работа с форматом данных JSON. URL: <https://ru.hexlet.io/blog/posts/ponyatie-json-i-rabota-s-formatom-dannyh-json?ysclid=mcmzfdngmu860802487> (дата обращения 20.08.2025).
6. NVD – Vulnerabilities. URL: <https://nvd.nist.gov/vuln> (дата обращения 20.08.2025).
7. Exploit Prediction Scoring System (EPSS). URL: <https://www.first.org/epss/>
8. The KEV Catalog | CISA. URL: <https://www.cisa.gov/resources-tools/resources/kev-catalog> (дата обращения 20.08.2025).

Финансовый университет при Правительстве Российской Федерации
Financial University under the Government of the Russian Federation

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 23.08.2025

Информация об авторах

Остапенко Григорий Александрович – д-р техн. наук, профессор, Финансовый университет при Правительстве Российской Федерации, e-mail: ost@fa.ru

Остапенко Александр Алексеевич – аспирант, Воронежский государственный технический университет, e-mail: alexostap123@gmail.com

Кондратьев Максим Витальевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Кривошеин Александр Сергеевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Макаров Юрий Вадимович – студент, Воронежский государственный технический университет, e-mail: makarov0130@gmail.com

AUTOMATION OF ASSESSMENT AND REGULATION OF RISKS OF IMPLEMENTATION OF CYBER-ATTACKS: PROCEDURES FOR COLLECTING, PROCESSING AND STORING DATA

**G.A. Ostapenko, A.A. Ostapenko, M.V. Kondratyev,
A.S. Krivoshein, Yu.V. Makarov**

The work is devoted to the formalization of a module for centralized collection, processing and storage of information about the components of a graph model of cyber attacks. The purpose of this work is to formulate the tasks that should be solved by implementing the module into the system, as well as implementing the algorithms themselves, which should provide automated collection of data about the components of the graph of cyber attacks, their processing and enrichment associated with increasing the integrity and quality of the data.

Keywords: cybersecurity, vulnerability, attack techniques, attack patterns, risk assessment, machine learning, CVSS, EPSS, MITRE ATT&CK.

Submitted 23.08.2025

Information about the authors

Gregory A. Ostapenko – Dr. Sc. (Technical), Professor, Financial University under the Government of the Russian Federation, e-mail: ost@fa.ru

Alexander A. Ostapenko – graduate student, Voronezh State Technical University, e-mail: alexostap123@gmail.com

Maksim V. Kondratyev – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Alexander S. Krivoshein – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Yuriy V. Makarov – student, Voronezh State Technical University, e-mail: makarov0130@gmail.com